UNITÉ D'ÉTUDE HUIT : SÉCURITÉ DE L'INFORMATION ET REPRISE APRÈS SINISTRE

Cette unité d'étude est la quatrième d'une série de quatre portant sur le **Domaine II : Sécurité de l'information** et le **Domaine III : Technologie de l'information** du programme d'examen CIA de l'IIA. Ces domaines représentent 25% et 20 %, respectivement, de la partie 3 de l'examen CIA et est évalués au niveau cognitif de **base.** Les parties pertinentes du syllabus sont mises en évidence ci-dessous. (Le programme complet se trouve à l'annexe A.)

8.1 : POLITIQUES ET CONTRÔLES LIÉS À LA SÉCURITÉ DE L'INFORMATION ET À LA CYBERSÉCURITÉ

1. Les organisations doivent être conscientes des risques uniques associés à un système d'information commerciale informatisé.
   a. L'informatique sûre peut être réalisée en utilisant des politiques et des procédures soigneusement conçues en conjonction avec un antivirus et un logiciel de contrôle d'accès.
   b. L'indicateur le plus complet de la conformité d'un système d'information aux procédures prescrites est le contrôle que le système exerce sur les données. Cela comprend la capacité et la complexité du système ainsi que l'accessibilité des données pour l'utilisateur final.
2. La sécurité de l'information et la cyber-sécurité sont généralement considérées comme synonymes ; cependant, la sécurité de l'information est plus étendue que la cyber-sécurité.
   a. La sécurité de l'information implique la sécurisation des données sous n'importe quelle forme (par exemple, le verrouillage des documents papier dans les classeurs et les salles de stockage des dossiers et le stockage des données électroniques sur le matériel informatique), tandis que la cyber-sécurité se concentre sur la protection des données électroniques.
   b. La cyber-sécurité est la sécurité de l'information appliquée au matériel informatique, aux logiciels et aux réseaux.
   c. Les principaux objectifs de la sécurité de l'information et de la cyber-sécurité sont la protection contre l'accès non autorisé aux données (sur papier ou sous forme électronique) et le maintien de l'intégrité et de la disponibilité des données.
      1) Le Comité sur les systèmes de sécurité nationale (CNSS) définit la sécurité de l'information comme *la protection de l'information et de ses éléments critiques, y compris les systèmes et le matériel qui utilisent, stockent et transmettent l'information*.
3. Les politiques constituent le fondement de mesures efficaces de sécurité de l'information et de cyber-sécurité.
   a. Le succès de la planification, de la conception et de la mise en œuvre des procédures de sécurité repose sur de solides politiques et sur le soutien de la direction.
   b. Les politiques régissent la façon de résoudre les problèmes et l'utilisation de l'infrastructure de TI pour résoudre les problèmes.
      1) Une politique efficace doit
         a) Respecter les lois et règlements
         b) être communiquée et expliquée au personnel concerné
         c) Être accepté par le personnel concerné
         d) être appliquée
4. Les normes facilitent la mise en œuvre des politiques en précisant les mesures à prendre pour s'y conformer. Les normes sont classées comme étant de facto et de jure.
   a. **Les normes de facto** sont des normes informelles qui ont été largement adoptées et acceptées.
   b. **Les normes de jure** sont des normes officielles qui ont été évaluées, approuvées et sanctionnées.
5. Les directives et procédures expliquent comment se conformer aux politiques en fournissant des instructions détaillées.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

De manière générale, la «sécurité» peut s'appliquer à presque tous les aspects des systèmes automatisés. La sensibilisation de l'auditeur interne à la sécurité de l'information devrait englober trois types généraux : logique, physique et communication.

6. **Intégrité des données**
   a. La difficulté de maintenir l'intégrité des données est la limite la plus importante des outils d'audit informatisés.
      1) Les preuves électroniques sont difficiles à authentifier et faciles à fabriquer.
      2) Les auditeurs internes doivent veiller à ne pas traiter les imprimés d'ordinateur comme des preuves papier traditionnelles. Les facteurs de sécurité des données relatifs à la preuve électronique doivent être pris en compte.
      3) Le degré de confiance de l'auditeur dans les éléments probants électroniques dépend de l'efficacité des contrôles exercés sur le système à partir duquel ces éléments sont recueillis.
      4) Lorsqu'il formule des recommandations concernant les coûts et les avantages de la sécurité informatique, l'auditeur devrait se concentrer sur les éléments suivants
         a) Perte potentielle si la sécurité n'est pas mise en œuvre,
         b) la probabilité des événements, et
         c) Le coût et l'efficacité de la mise en œuvre et du fonctionnement de la sécurité informatique.
      5) Le contrôle le plus important est l'adoption d'une politique de sécurité du réseau à l'échelle de l'organisation. Cette politique devrait promouvoir les objectifs suivants :
         a) **Disponibilité.** Les utilisateurs prévus et autorisés devraient pouvoir accéder aux données pour atteindre les objectifs de l'organisation.
         b) **Sécurité, vie privée et confidentialité**. Le secret des informations qui pourraient nuire à l'organisation si elles étaient divulguées au public ou aux concurrents devrait être assuré.
         c) **Intégrité.** Toute modification non autorisée ou accidentelle des données doit être évitée.
   b. De nombreux contrôles autrefois effectués par des personnes distinctes peuvent être concentrés dans des systèmes informatiques. Par conséquent, une personne qui a accès à l'ordinateur peut exécuter des fonctions incompatibles. Par conséquent, d'autres procédures de contrôle peuvent être nécessaires pour atteindre les objectifs de contrôle habituellement atteints par la séparation des fonctions.
      1) Ces contrôles peuvent être classés en contrôles physiques ou logiques. Les contrôles physiques sont divisés en deux sous-catégories : les contrôles d'accès physiques et les contrôles environnementaux.
7. **Contrôles de sécurité physique**
   a. **Les contrôles d'accès physique** limitent l'accès physique aux systèmes.
      1) Les claviers permettent d'entrer un mot de passe ou un code pour accéder à un emplacement physique ou à un système informatique.
      2) Les commandes du lecteur de carte sont basées sur la lecture des informations d'une bande magnétique sur une carte de crédit, de débit ou autre carte d'accès. Des contrôles peuvent ensuite être appliqués aux informations sur le titulaire de la carte contenues sur la bande magnétique.
      3) Les technologies biométriques sont des méthodes automatisées permettant d'établir l'identité d'une personne à l'aide de traits physiologiques ou comportementaux. Ces caractéristiques comprennent les empreintes digitales, les motifs dans l'iris de l'œil, la géométrie de la main, la dynamique des signatures, la parole et la dynamique des touches.
   b. **Les contrôles environnementaux** sont également conçus pour protéger les biens matériels d'information de l'organisation. Les plus importantes sont
      1) Contrôle de la température et de l'humidité
      2) Système d'extinction d'incendie gazeux (pas d'eau)

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

3) Centre de données non situé sur un mur extérieur
4) Bâtiment abritant un centre de données qui n'est pas situé dans une plaine inondable

8. **Contrôles logiques**

a. Des contrôles de sécurité logiques sont nécessaires en raison de l'utilisation de réseaux de communication et de connexions à des systèmes externes. L'identification et l'authentification des utilisateurs, la restriction d'accès et la génération de pistes d'audit sont requises dans cet environnement. Ainsi, des contrôles d'accès ont été mis au point pour prévenir l'utilisation ou la manipulation inappropriée des fichiers de données et des programmes. Ils veillent à ce que seules les personnes ayant une finalité et une autorisation justifiées aient accès aux systèmes informatiques.

1) Les logiciels de **contrôle d'accès** a) protègent les fichiers, les programmes, les dictionnaires de données, le traitement, etc. contre les accès non autorisés ; b) restreignent l'utilisation de certains dispositifs (p. ex., les terminaux) ; et c) peuvent fournir une piste d'audit pour les tentatives d'accès réussies ou non réussies. Par exemple, un pare-feu sépare les réseaux internes des réseaux externes.

2) **Mots de passe et numéros d'identification.** L'utilisation de mots de passe et de numéros d'identification est un contrôle efficace dans un système en ligne pour empêcher l'accès non autorisé aux fichiers informatiques. Les listes des personnes autorisées sont conservées dans l'ordinateur. L'entrée de mots de passe ou de numéros d'identification, un ensemble préétabli de questions personnelles et l'utilisation de badges, de cartes magnétiques ou de cartes à balayage optique peuvent être combinés pour éviter tout accès non autorisé.

a) Une carte de sécurité peut être utilisée avec un ordinateur personnel de sorte que les utilisateurs doivent se connecter avec un identifiant et un mot de passe. La carte contrôle le système d'exploitation de la machine et enregistre les données d'accès (date, heure, durée, etc.).

b) Une authentification correcte des utilisateurs au moyen d'un mot de passe nécessite des procédures de génération de mots de passe pour s'assurer que les mots de passe valides ne sont connus que par les personnes concernées. Ainsi, un mot de passe ne devrait pas être affiché lorsqu'il est saisi au clavier.

c) La sécurité du mot de passe peut également être compromise d'autres façons. Par exemple, les procédures de connexion peuvent être lourdes et fastidieuses. Ainsi, les utilisateurs stockent souvent des séquences de connexion sur leur ordinateur personnel et les invoquent lorsqu'ils veulent utiliser les fonctions de l'ordinateur central. Le risque de cette pratique est que toute personne ayant accès aux ordinateurs personnels puisse se connecter à l'ordinateur central.

d) Pour être plus efficaces, les mots de passe doivent être composés de lettres, de symboles et de chiffres aléatoires. Ils ne doivent pas contenir de mots ou de phrases.

3) **Des attributs de fichier** peuvent être assignés pour contrôler l'accès et l'utilisation des fichiers. Les exemples sont en lecture/écriture, en lecture seule, archivés et cachés.

4) Une **table d'autorisation de périphérique** limite l'accès aux fichiers aux périphériques physiques qui devraient logiquement avoir besoin d'un accès. Par exemple, parce qu'il n'est pas logique pour quiconque d'accéder au fichier des comptes clients à partir d'un terminal de fabrication, la table d'autorisation des dispositifs refusera l'accès même lorsqu'un mot de passe valide est utilisé.

a) De tels tests sont souvent appelés tests de compatibilité, car ils vérifient si un numéro de code est compatible avec l'utilisation potentielle d'informations. Ainsi, un utilisateur peut être autorisé à saisir uniquement certains types de données, à n'avoir accès qu'à certaines informations, à y avoir accès mais sans pouvoir de mise à jour, ou à n'utiliser le système qu'à certains moments. Les listes ou les tableaux d'utilisateurs ou d'appareils autorisés sont parfois appelés matrices de contrôle d'accès.

5) Un journal d'**accès au système** enregistre toutes les tentatives d'utilisation du système. La date et l'heure, les codes utilisés, le mode d'accès, les données concernées et les interventions de l'opérateur sont enregistrés.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

6) **Le chiffrement** utilise un algorithme fixe pour manipuler le texte en clair.

7) **L'élimination contrôlée des** documents est un moyen de faire respecter les restrictions d'accès en détruisant les données lorsqu'elles ne sont plus utilisées. Ainsi, les documents papier peuvent être déchiquetés et les supports magnétiques peuvent être effacés.

8) **La déconnexion automatique** (déconnexion) des terminaux de données inactifs peut empêcher l'affichage de données sensibles sur un terminal de données sans surveillance.

9) **Personnel de sécurité.** Une organisation peut avoir besoin d'embaucher des spécialistes de la sécurité. Par exemple, l'élaboration d'une politique de sécurité de l'information pour l'organisation, la formulation de commentaires sur les contrôles de sécurité dans les nouvelles applications, la surveillance et les enquêtes sur les tentatives d'accès infructueuses sont des tâches appropriées de l'agent de sécurité.

9. **Sécurité Internet**

a. La connexion à Internet pose des problèmes de sécurité.

1) Ainsi, la politique de sécurité du réseau à l'échelle de l'organisation devrait au moins inclure les éléments suivants

a) Système de gestion de compte d'utilisateur

b) Installation d'un pare-feu Internet

c) Des méthodes telles que le chiffrement pour s'assurer que seul l'utilisateur prévu reçoit l'information et que l'information est complète et exacte

2) La gestion des comptes d'utilisateurs implique l'installation d'un système pour s'assurer que

a) Les nouveaux comptes sont ajoutés correctement et ne sont attribués qu'aux utilisateurs autorisés.

b) Les anciens comptes et les comptes inutilisés sont rapidement supprimés.

c) Les mots de passe sont changés périodiquement et les employés apprennent à choisir un mot de passe difficile à deviner (p. ex. un mot de passe d'au moins six caractères différents qui ne forment pas un mot).

3) Un **pare-feu** sépare un réseau interne d'un réseau externe (p. ex. Internet) et empêche le passage de certains types de trafic. Il identifie les noms, les adresses IP (protocole Internet), les applications, etc. et les compare aux règles d'accès programmées.

a) Un pare-feu peut présenter l'une des caractéristiques suivantes :

i) Un **système de filtrage de paquets** examine chaque paquet réseau entrant et dépose (ne transmet pas) les paquets non autorisés. Ce type de pare-feu compare les adresses source et de destination à une liste autorisée et examine spécifiquement les en-têtes et autres zones des paquets de données. Étant donné qu'il examine les paquets séparément les uns des autres, il peut omettre certains types d'attaques. Le filtrage de paquets peut être optimisé des manières suivantes.

- **Inspection dynamique**. Ce pare-feu optimise le filtrage des paquets en surveillant les flux de paquets en général. Des tables d'état sont utilisées pour suivre les données acheminées via plusieurs paquets. Le pare-feu analyse toutes les conversations à des fins de justesse et de légitimité.
- **Traduction d'adresses réseau (NAT, « Network address translation »)** Les pare-feux disposant de fonctions de filtrage de paquets et d'inspection dynamique de paquets peuvent utiliser la NAT pour masquer les adresses IP de leur ordinateur hôte interne contre les renifleurs.

ii) Un **serveur proxy** sert d'intermédiaire pour les requêtes entre une application cliente et le serveur réel.

iii) Une **passerelle d'application** est un proxy au niveau de l'application qui limite le trafic à des applications spécifiques et empêche les requêtes malveillantes d'être soumises aux applications Web.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

iv) Une **passerelle de niveau circuit** connecte un dispositif interne, par exemple une imprimante réseau, à un port TCP/IP externe. Elle peut identifier une session TCP valide.

b) Les systèmes de pare-feu produisent habituellement des rapports sur l'utilisation d'Internet à l'échelle de l'organisation, les habitudes d'utilisation inhabituelles et les tentatives de pénétration du système. Ces rapports sont très utiles à l'auditeur interne en tant que méthode de surveillance continue, ou d'enregistrement, du système.

i) Les pare-feu n'offrent pas une protection adéquate contre les virus informatiques. Ainsi, une organisation devrait inclure une ou plusieurs mesures antivirus dans sa politique de sécurité réseau.

4) Les données circulant sur le réseau peuvent être codées de manière à ce qu'elles soient indéchiffrables pour n'importe qui, à l'exception du destinataire prévu.

5) Autres contrôles

a) Les mesures d'**authentification** vérifient l'identité de l'utilisateur, garantissant ainsi que seuls les utilisateurs prévus et autorisés ont accès au système.

i) La plupart des systèmes de pare-feu fournissent des procédures d'authentification.

ii) Les contrôles d'accès sont les procédures les plus courantes.

b) **Les sommes de contrôle** permettent d'assurer l'intégrité des données en vérifiant si le fichier a été modifié. Le système calcule une valeur pour un fichier, puis vérifie si cette valeur est égale à la dernière valeur connue pour ce fichier. Si les chiffres sont les mêmes, le dossier est probablement demeuré inchangé.

10. **Stockage des données**

a. Le stockage de toutes les données associées sur un seul périphérique de stockage crée des problèmes de sécurité.

1) Si des dysfonctionnements matériels ou logiciels surviennent ou si un accès non autorisé est obtenu, les résultats pourraient être désastreux.

2) Il faut mettre davantage l'accent sur la sécurité pour assurer la sauvegarde et restreindre l'accès à la base de données.

a) Par exemple, le système peut utiliser la double journalisation, c'est-à-dire l'utilisation de deux journaux des transactions écrits simultanément sur des supports de stockage séparés. Il peut également utiliser une technique d'instantané pour saisir les valeurs des données avant et après le traitement des transactions. Les fichiers qui stockent ces valeurs peuvent être utilisés pour reconstruire la base de données en cas de perte de données ou de corruption.

3) La responsabilité de créer, de maintenir, de sécuriser et de restreindre l'accès à la base de données incombe à l'administrateur de la base de données (DBA).

4) Un système de gestion de base de données (SGBD) comprend des fonctions de sécurité. Ainsi, l'accès d'un utilisateur donné peut être limité à certains champs de données ou à certaines vues logiques selon les tâches assignées à la personne.

b. Le **Cloud computing** libère les organisations de la nécessité de gérer le stockage des applications et des données parce que tous les logiciels et les données sont stockés sur l'Internet.

1) Le Cloud computing est définie comme une capacité informatique normalisée (services, logiciels, infrastructure) offerte par Internet de façon libre-service et payante.

2) Les avantages du Cloud computing comprennent la réduction des investissements dans l'infrastructure et des coûts de maintenance, l'augmentation de la mobilité et la réduction des coûts de personnel et de services publics.

3) Les inconvénients du Cloud computing comprennent moins de contrôle qu'un service informatique interne, plus de difficulté à assurer la sécurité et la confidentialité des données, et moins de compatibilité avec les outils et logiciels existants.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

8.2 : AUTHENTIFICATION, AUTORISATION ET CHIFFREMENT

1. Authentification des applications

a. L'authentification d'application est un moyen de prendre l'identité d'un utilisateur du système d'exploitation sur lequel l'utilisateur travaille et de la transmettre à un serveur d'authentification pour vérification. Ceci peut être conçu dans une application dès sa conception.

b. **L'authentification à deux niveaux** (aussi appelée **authentification à deux facteurs**) nécessite (1) un nom d'utilisateur et un mot de passe et (2) des informations connues uniquement de l'utilisateur (par exemple, des informations telles que "marque et modèle de la première voiture de l'utilisateur" ou "aliment préféré") ou quelque chose (s) dont il dispose immédiatement (par exemple, un jeton matériel physique).

c. Il existe trois classes d'informations d'authentification.

1) Informations mémorisées : nom, date de naissance, numéro de compte, mot de passe, PIN

2) Objets en sa possession : badge, carte plastique, clé, anneau.

3) Caractéristiques personnelles : empreinte digitale, empreinte vocale, taille de la main, signature, motifs dans l'iris de l'œil

2. Aperçu du chiffrement

a. La technologie de chiffrement convertit les données en un code. Un programme code les données avant la transmission. Un autre programme le décode après la transmission. Les utilisateurs non autorisés peuvent toujours avoir accès aux données, mais sans la clé de chiffrement, ils ne peuvent pas décoder l'information.

b. Le logiciel de chiffrement utilise un algorithme fixe (une procédure étape par étape, généralement mathématique) pour manipuler le texte en clair (la forme compréhensible du texte crypté) et une clé de chiffrement pour introduire une variation. L'information est envoyée sous sa forme manipulée (cyphertext), et le destinataire traduit l'information en texte clair. Bien qu'il soit possible d'accéder aux données en tapant sur la ligne de transmission, la clé de chiffrement est nécessaire pour comprendre les données envoyées.

1) Instructions machine nécessaires pour coder et décoder les données peuvent représenter une augmentation de 20 % à 30 % de la surcharge du système.

c. La technologie de chiffrement peut être matérielle ou logicielle. Il existe deux grands types de logiciels de chiffrement : à clé publique et à clé privée.

3. Chiffrement à clé publique (asymétrique)

a. Le chiffrement à clé publique (asymétrique) nécessite une paire de clés : une clé publique et une clé privée. Ces paires de clés sont émises par une tierce partie de confiance appelée autorité de certification (par exemple, VeriSign, Thawte, GoDaddy).

1) La clé publique de chaque destinataire est disponible dans le répertoire de l'autorité de certification, mais la clé privée associée n'est connue que du destinataire.

2) Toute personne qui souhaite envoyer un message sécurisé le chiffre à l'aide de la clé publique du destinataire prévu. Le destinataire décrypte ensuite le message à l'aide de la clé privée. Les deux clés sont mathématiquement liées de sorte qu'un message crypté avec une clé ne peut être décrypté qu'avec l'autre clé.

b. Cet arrangement est plus sûr qu'un système à clé unique, dans lequel les parties doivent s'entendre et transmettre une seule clé unique qui pourrait être interceptée.

1) RSA, du nom de ses développeurs (Rivest, Shamir et Adelman), est la méthode à clé publique la plus utilisée.

c. Une **signature électronique** est un moyen d'authentification d'un document électronique, par exemple, de la validité d'un bon de commande, de l'acceptation d'un contrat ou d'informations financières.

1) L'expéditeur utilise sa clé privée pour encoder tout ou partie du message et le destinataire utilise la clé publique de l'expéditeur pour le décoder. Par conséquent, si cette clé décode le message, l'expéditeur doit l'avoir écrit.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

2) Une variante consiste à envoyer le message à la fois en texte clair et en texte crypté. Si la version décodée correspond à la version en texte clair, aucune modification n'a eu lieu.

d. Un **certificat électronique** est un autre moyen d'authentification utilisé dans le commerce électronique. L'autorité de certification délivre un certificat électronique codé qui contient (1) le nom du titulaire, (2) une copie de sa clé publique, (3) un numéro de série et (4) une date d'expiration. Le certificat vérifie l'identité du titulaire.

1) Le destinataire d'un message codé envoyé par le titulaire utilise la clé publique de l'autorité de certification (disponible sur Internet) pour décoder le certificat inclus dans le message. Le destinataire détermine ensuite que le certificat a été délivré par l'autorité de certification. De plus, le destinataire peut utiliser la clé publique et les données d'identification de l'expéditeur pour envoyer une réponse codée.

a) Ces méthodes peuvent être utilisées pour les transactions entre vendeurs et acheteurs par carte de crédit.

2) Un certificat peut également être utilisé pour fournir aux clients l'assurance qu'un site Web est authentique.

e. L'infrastructure à clé publique permet l'échange sécurisé d'argent et d'informations sur Internet. Il facilite ainsi le commerce électronique.

1) Les deux principaux protocoles cryptographiques pour les communications sécurisées sur Internet sont SSL (Secure Sockets Layer) et TLS (Transport Layer Security).

a) Lorsque HTTP (Hypertext Transfer Protocol, un protocole de niveau supérieur qui rend le World Wide Web possible) est utilisé conjointement avec SSL ou TLS, il est appelé HTTPS (HTTP Secure).

b) Les URL des pages Web sécurisées où les acheteurs saisissent leur numéro de carte de crédit passent le plus souvent de http:// à https://.

2) Les services d'horodatage numérique vérifient l'heure (et éventuellement le lieu) d'une transaction. Par exemple, un document peut être envoyé à un service qui appose son cachet numérique, puis le transmet.

4. Chiffrement par clé privée (symétrique)

a. Le chiffrement à clé privée, ou symétrique, est moins sûr que la méthode à clé publique parce qu'il ne nécessite qu'une seule clé (secrète) pour chaque paire de parties qui veulent s'envoyer des messages codés.

1) Le Data Encryption Standard (DES), une méthode à clé privée partagée développée par le gouvernement américain, est la méthode à clé secrète la plus répandue. Il est basé sur des nombres à 56 chiffres binaires.

2) L'Advanced Encryption Standard (AES) est un algorithme cryptographique utilisé par les organisations gouvernementales américaines pour protéger les informations sensibles.

a) Le National Institute of Standards and Technology a commencé à développer l'AES en 1997, lorsqu'il a annoncé la nécessité d'un nouvel algorithme pour le DES, qui devenait vulnérable aux attaques par force brute.

8.3 : PROTECTION DE L'INFORMATION

1. Objectif opérationnel

a. Selon le modèle eSAC (*Electronic Systems Assurance and Control*) publié par l'IIA, les cinq catégories suivantes constituent des objectifs d'assurance des activités informatiques :

1) **Disponibilité.** L'organisation doit s'assurer que l'information, les processus et les services sont disponibles en tout temps.

2) **Capacité.** L'organisation doit veiller à ce que les transactions soient effectuées de façon fiable et en temps opportun.

3) **Fonctionnalité.** L'organisation doit s'assurer que les systèmes sont conçus selon les spécifications de l'utilisateur pour répondre aux exigences opérationnelles.

4) **Protection.** L'organisation doit s'assurer qu'une combinaison de contrôles physiques et logiques empêche l'accès non autorisé aux données du système ou leur utilisation.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

5) **Responsabilité.** L'organisation doit s'assurer que le traitement des transactions est exact, complet et non réfutable.

b. L'une des principales préoccupations en matière de protection concerne les logiciels malveillants (malware). La TI devrait avoir des mesures de protection en place pour empêcher l'accès, l'utilisation ou les dommages non autorisés.

1) Des contrôles de l'accès et des processus de gestion des changements devraient être en place pour atteindre l'objectif de protection.

2) En outre, la sensibilisation à la sécurité de toutes les parties concernées devrait être renforcée. Par conséquent, l'objectif d'assurance des activités de responsabilité est également pertinent. Les rôles, les actions et les responsabilités en matière de sécurité devraient être définis.

2. Logiciels malveillants (Malware)

a. Un logiciel malveillant peut exploiter une faille ou une faiblesse connue dans une application ou un programme de système d'exploitation pour échapper aux mesures de sécurité.

1) Une telle vulnérabilité peut avoir été causée par une erreur de programmation. Elle peut aussi avoir été créé intentionnellement (mais pas malicieusement) pour permettre à un programmeur un simple accès (une porte arrière) pour corriger le code.

2) Ayant contourné les contrôles de sécurité, l'intrus peut endommager immédiatement le système ou installer un logiciel malveillant. Dans certains cas, l'infection par des logiciels malveillants peut avoir peu ou pas d'effets perceptibles par les utilisateurs.

b. Un **cheval de Troie** est un programme apparemment innocent (p. ex., un tableur) qui comprend une fonction cachée qui peut causer des dommages lorsqu'il est activé.

1) Par exemple, il peut contenir un virus, qui est un code de programme qui se copie de fichier en fichier. Le virus peut détruire des données ou des programmes. Les virus se propagent couramment par les pièces jointes et les téléchargements de courriels.

2) Un cheval de Troie peut agir comme une porte dérobée pour contourner l'authentification normale et fournir un accès non autorisé et à distance aux données, ordinateurs et réseaux.

c. Un **virus** est un code malveillant qui se fixe à un support de stockage, des documents ou des fichiers exécutables et est répandu lorsque les fichiers sont partagés avec d'autres utilisateurs. Le macrovirus est un type de virus. Il utilise la fonction macro de logiciels tels que Microsoft Word® pour créer un code exécutable. En réponse, Microsoft a créé de nouvelles extensions de fichiers qui indiquent si un fichier contient des macros ou non (par exemple, .xlsx : ne contient pas de macros, .xlsm : contient des macros).

d. Un **ver** ne se copie pas d'un fichier à l'autre, mais d'ordinateur à ordinateur, souvent très rapidement. La réplication répétée surcharge un système en épuisant la mémoire ou en surchargeant la capacité de trafic réseau.

e. Une **bombe logique** ressemble beaucoup à un cheval de Troie, sauf qu'elle ne s'active que lors d'un événement particulier, par exemple, à une certaine date comme le vendredi 13 avril, le Jour du Poisson d'avril, etc.

f. Les logiciels malveillants peuvent créer un **déni de service** en submergeant un système ou un site Web avec plus de trafic qu'il ne peut gérer.

g. **Un logiciel rançon est un** type de logiciel malveillant qui menace de publier les données de la victime ou d'empêcher les utilisateurs d'accéder à leur système ou à leurs fichiers personnels et qui exige le paiement d'une rançon afin de pouvoir y accéder à nouveau.

3. Contrôles contre les logiciels malveillants

a. Les contrôles visant à prévenir ou à détecter l'infection par des logiciels malveillants sont particulièrement importants pour les serveurs de fichiers des grands réseaux. Les objectifs de contrôle généraux sont les suivants :

1) Une politique ne devrait exiger que l'utilisation de logiciels autorisés.

2) Une politique devrait exiger le respect des accords de licence.

3) Une politique devrait créer une obligation de rendre compte pour les personnes autorisées à entretenir les logiciels.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

4) Une politique devrait exiger des mesures de protection lorsque des données ou des programmes sont obtenus au moyen de supports externes.
5) Le logiciel antivirus doit surveiller en permanence le système pour détecter les virus (ou vers) et les éradiquer. Il devrait également être immédiatement mis à jour dès que des informations sur de nouvelles menaces sont disponibles.
6) Les logiciels et les données des systèmes critiques devraient être régulièrement examinés.
7) Les enquêtes sur les dossiers non autorisés ou les modifications doivent être routinières.
8) Les pièces jointes et les téléchargements de courriels (et les fichiers sur des supports non autorisés ou provenant de réseaux non sécurisés) doivent être vérifiés.
9) Des procédures devraient être établies et la responsabilité de la lutte contre les logiciels malveillants devrait être attribuée.
   a) Les procédures devraient tenir compte du fait qu'une autre organisation qui a transmis du matériel infecté par des logiciels malveillants peut l'avoir fait sans le savoir et avoir besoin d'aide. Toutefois, si de tels événements se reproduisent à plusieurs reprises, la résiliation d'accords ou de contrats peut être indiquée.
   b) Les procédures et les politiques doivent être documentées et les employés doivent en comprendre les raisons.
10) Des plans de continuité (reprise) des activités devraient être rédigés, p. ex. des plans de sauvegarde des données et des logiciels.
11) Les informations sur les logiciels malveillants doivent être vérifiées et des alertes appropriées doivent être données.
12) Le personnel responsable doit être conscient de la possibilité de canulars, qui sont de faux messages visant à susciter la crainte d'une attaque par un logiciel malveillant. Par exemple, un message électronique fallacieux peut être reçu demandant aux utilisateurs de supprimer des fichiers supposément compromis.
13) Il faut s'en remettre à un personnel qualifié pour distinguer les canulars des logiciels malveillants.

b. Ce qui suit sont des contrôles spécifiques pour prévenir ou détecter l'infection par des logiciels malveillants :
   1) Tous les supports informatiques (entrants ou sortants) peuvent être scannés par des ordinateurs sheep dip (dédiés).
   2) Les supports non filtrés ne devraient pas être autorisés sur les ordinateurs de l'organisation.
   3) L'analyse peut être effectuée sur des ordinateurs autonomes ou sur des réseaux comme autre ligne de défense en cas d'échec du contrôle des supports.
   4) Le logiciel peut résider dans la mémoire pour rechercher les logiciels malveillants communiqués par l'intermédiaire d'un réseau.
   5) Les passerelles de courrier électronique peuvent être dotées d'un logiciel permettant d'analyser les pièces jointes.
   6) Les serveurs de réseau peuvent disposer de logiciels permettant de détecter et d'effacer ou de stocker les logiciels malveillants.
   7) Le logiciel de numérisation d'un appareil autonome doit être mis à niveau lorsqu'il est mis en réseau.

c. Le recours à une expertise externe plutôt qu'interne pour faire face aux problèmes de logiciels malveillants peut être plus coûteux et prendre plus de temps, mais moins de risques.
   1) Les fournisseurs de services externes devraient être assujettis aux modalités d'un contrat, et l'accès et d'autres contrôles devraient être en place.

d. Les ordinateurs et les supports hors site des employés devraient être soumis à des contrôles de logiciels malveillants, tels que le filtrage.

e. Les réponses aux menaces par le biais de canaux secrets et de programmes de chevaux de Troie sont les suivantes :
   1) Les achats doivent porter sur des produits évalués auprès de fournisseurs de confiance.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

2) Les achats doivent être en code source afin d'être vérifiables. Ce code doit être inspecté et testé avant utilisation.
3) L'accès au code et les modifications qui y sont apportées devraient être restreints après sa mise en service.
4) La disponibilité des correctifs de sécurité pour les bogues dans les programmes doit être surveillée en permanence, en particulier en ce qui concerne des éléments tels que les systèmes d'exploitation réseau, les serveurs de messagerie, les routeurs et les pare-feu. Les correctifs doivent être testés et installés rapidement.
5) Les employés de confiance devraient être affectés à des systèmes clés.
6) Les chevaux de Troie connus peuvent être détectés par balayage.
7) L'examen des sorties de données, par exemple, à travers le pare-feu, peut détecter des activités suspectes méritant une enquête.

f. Les hôtes sont les cibles les plus communes dans un réseau parce qu'ils fournissent des services à d'autres hôtes demandeurs.
1) Les mesures de protection comprennent l'installation rapide des correctifs, corrections et mises à jour les plus récents.
a) Les effets des mesures de protection sur d'autres éléments du système devraient être pris en compte.
b) Les mises à jour doivent être testées avant l'installation.

4. Types d'attaques

a. **Attaques par mot de passe**

1) Plusieurs méthodes peuvent être utilisées.
a) Une attaque par force brute utilise un logiciel de craquage de mots de passe pour essayer un grand nombre de combinaisons de lettres et de chiffres afin d'accéder à un réseau.
i) Une variante simple est l'utilisation d'un logiciel de craquage de mots de passe qui essaie tous les mots d'un dictionnaire.
b) Les mots de passe (et les comptes utilisateurs) peuvent également être découverts par les chevaux de Troie, l'usurpation d'adresse IP et les renifleurs de paquets.
i) Le hameçonnage (usurpation d'identité) est une fausse représentation de l'identité dans le cyberespace. Le **hameçonnage** est une méthode permettant d'obtenir électroniquement des renseignements confidentiels par la tromperie. L'auteur met en place un site Web qui semble légitime, mais qui n'a d'autre but que d'obtenir des informations sur la victime. Les escroqueries par hameçonnage sont souvent déclenchées par l'usurpation d'adresse électronique, dans laquelle l'auteur envoie des courriels qui semblent provenir d'une véritable institution financière. Lorsque la victime clique sur le lien vers ce qu'elle croit être le site Web de l'établissement, la victime est redirigée sans le savoir vers le site Web de l'agresseur.
ii) Le reniflage est l'utilisation d'un logiciel pour écouter les informations envoyées par un utilisateur à l'ordinateur hôte d'un site Web.
2) Une fois qu'un attaquant a accès, il peut faire tout ce que l'utilisateur légitime aurait pu faire.
a) Si cet utilisateur a un accès privilégié, l'attaquant peut créer une porte dérobée pour faciliter l'accès futur malgré les changements de mot de passe et de statut.
b) L'attaquant peut également être en mesure d'exploiter l'accès initial pour obtenir de plus grands privilèges que l'utilisateur légitime.
3) Si un utilisateur a le même mot de passe pour plusieurs hôtes, craquer ce mot de passe pour un seul compromet tout.
4) Les méthodes expressives pour contrer les attaques par mot de passe sont l'authentification par mot de passe unique et l'authentification cryptographique.
5) Les mots de passe optimaux sont générés au hasard, des combinaisons de huit caractères ou plus de chiffres, de lettres majuscules et minuscules et de symboles spéciaux.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

a) Un inconvénient est que les utilisateurs notent souvent des mots de passe qui sont difficiles à retenir. Cependant, un logiciel a été développé pour crypter les mots de passe à conserver sur un ordinateur de poche. Ainsi, l'utilisateur n'a besoin de connaître qu'un seul mot de passe.

b. Une **attaque d'homme au milieu** profite de la mise en réseau, du reniflage de paquets et des protocoles de routage et de transport.

1) Ces attaques peuvent être utilisées pour

a) Voler les données

b) Obtenir l'accès au réseau pendant la session active d'un utilisateur légitime

c) Analyser le trafic sur le réseau pour connaître son fonctionnement et ses utilisateurs

d) Insérer de nouvelles données ou modifier les données transmises

e) Refuser le service

2) Le chiffrement est la réponse efficace aux attaques de l'homme au milieu. Les données cryptées seront inutiles à l'attaquant à moins qu'elles ne puissent être décryptées.

c. Une attaque par **déni de service (DOS)** est une tentative de surcharger un système (par exemple, un réseau ou un serveur Web) avec de faux messages afin qu'il ne puisse pas fonctionner (un crash système).

1) Une attaque DOS distribuée (DDOS) provient de sources multiples, par exemple, les machines de parties innocentes infectées par des chevaux de Troie. Lorsqu'ils sont activés, ces programmes envoient des messages à la cible et laissent la connexion ouverte.

2) Un DOS peut établir autant de connexions réseau que possible pour exclure d'autres utilisateurs, surcharger la mémoire primaire ou corrompre les systèmes de fichiers.

3) Réponses

a) Les pare-feu ne devraient pas permettre l'utilisation de canaux de clavardage relais Internet ou d'autres ports TCP/IP, sauf à des fins commerciales. Ainsi, l'organisation devrait déterminer quels relais ont été installés, p. ex. par des employés connectés à des réseaux privés virtuels par câble ou DSL.

i) Ces méthodes, systèmes de détection d'intrusion et tests de pénétration peuvent empêcher l'utilisation d'un système pour effectuer une attaque DOS.

b) La meilleure protection de la cible est le fournisseur d'accès Internet (FAI). Le FAI peut établir des limites de débit pour les transmissions vers le site Web de la cible.

i) Ainsi, seul un nombre défini de paquets de messages ayant certaines caractéristiques sont autorisés à atteindre le site.

d. **Le piratage de logiciels** est un problème pour les fournisseurs. Toute duplication du logiciel au-delà de ce qui est autorisé dans le contrat de licence du logiciel est illégale.

1) La meilleure façon de détecter une copie illégale d'un logiciel d'application est de comparer le numéro de série affiché à l'écran avec le numéro de série du fournisseur.

2) L'utilisation de logiciels sans licence augmente le risque d'introduire des virus informatiques dans l'organisation. Ces logiciels sont moins susceptibles d'avoir été soigneusement testés.

3) Afin d'éviter toute responsabilité juridique, des contrôles devraient également être mis en place pour empêcher l'utilisation de logiciels non autorisés qui ne sont pas du domaine public. Un contrat de licence de logiciel permet à un utilisateur d'utiliser un nombre spécifié ou illimité de copies d'un produit logiciel à des endroits donnés, sur des machines particulières ou dans toute l'organisation. L'accord peut restreindre la reproduction ou la revente, et peut fournir un support client ultérieur et des améliorations du produit.

4) Le piratage de logiciels peut exposer le personnel d'une organisation à des sanctions civiles et pénales. La Business Software Alliance (BSA) est un groupe de commerce mondial qui coordonne les efforts des fournisseurs de logiciels pour poursuivre les auteurs de la duplication illégale de logiciels.

e. **La falsification informatique** est l'accès non autorisé à des programmes, données ou ordinateurs utilisés à des fins frauduleuses ou pour endommager un autre ordinateur, données ou programme.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

f. **Le piratage informatique** désigne l'intrusion non autorisée dans un ordinateur ou un réseau à des fins de modification ou d'altération (c.-à-d. altération) du logiciel ou du matériel informatique dans le but d'atteindre un but autre que l'objectif initial du créateur.

5. Contre-mesures -- Systèmes de détection d'intrusion (SDI)

a. Si le système informatique d'une organisation dispose de connexions externes, un SDI est nécessaire pour réagir aux atteintes à la sécurité.

1) Le SDI complète les pare-feu du système informatique. Il répond aux attaques contre

a) L'infrastructure du réseau (protégée par le composant SDI du réseau)

i) Routeurs

ii) Commutateurs

iii) Largeur de bande

b) Serveurs (protégés par le composant SDI hôte)

i) Systèmes d'exploitation

ii) Applications

2) Un SDI répond à une attaque en

a) Agissant soi-même

b) Alertant le système de gestion

b. Un SDI hôte offre une protection maximale uniquement lorsque le logiciel est installé sur chaque ordinateur. Il peut fonctionner de la manière suivante :

1) La réponse agressive consiste à surveiller chaque appel sur le système d'exploitation et l'application au fur et à mesure qu'il se produit.

2) Une méthode moins efficace pour prévenir les attaques est l'analyse des fichiers journaux d'accès.

3) Un SDI hôte peut également identifier les processus douteux et vérifier la sécurité des fichiers système.

c. Un SDI réseau fonctionne en utilisant des capteurs pour examiner les paquets se déplaçant sur le réseau. Chaque capteur ne surveille que le segment du réseau auquel il est connecté. Un paquet est examiné s'il correspond à une signature.

1) Les signatures de chaînes de caractères (certaines chaînes de caractères) sont des signes potentiels d'une attaque.

2) Les signatures de port alertent le SDI qu'un point sujet à de fréquentes tentatives d'intrusion peut être attaqué.

a) Un port dans ce sens (par opposition aux ports physiques série et parallèle sur un ordinateur personnel) est une connexion logique au système.

i) Un numéro de port inclus dans l'en-tête du message indique comment le message sera traité. Comme de nombreux numéros de port sont largement connus, un attaquant peut être capable d'envoyer des messages pour déterminer si les ports sont ouverts et donc vulnérables.

3) Une signature d'en-tête est une combinaison suspecte dans un en-tête de paquet.

d. Le SDI préférable combine les composants SDI hôte et SDI réseau.

1) Un SDI hôte a un plus grand potentiel pour prévenir une attaque spécifique, mais le SDI réseau fournit une perspective globale nécessaire. Ainsi, un SDI hôte doit être en place pour chaque hôte, avec un SDI réseau pour l'ensemble du système.

e. La détection basée sur la connaissance est basée sur les informations relatives aux faiblesses du système et recherche les intrusions qui en tirent parti.

1) Ce type de SDI dépend de la mise à jour fréquente et coûteuse des informations sur les méthodes d'intrusion. Elle est également spécialisée en ce qui concerne ces méthodes et les méthodes du système d'exploitation.

a) Les problèmes sont aggravés lorsque différentes versions du système d'exploitation (ou différents systèmes d'exploitation) sont en place.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

f. La détection basée sur le comportement présume qu'une attaque causera une anomalie observable. Le comportement réel et normal du système (un modèle des opérations prévues) sont comparés. Une anomalie entraîne une alerte.

1) Cette approche est plus complète que l'approche fondée sur la connaissance car chaque attaque doit être détectée. Cependant, le niveau de précision est plus faible. Des fausses alarmes peuvent être générées, de sorte que le modèle doit être mis à jour chaque fois que des changements opérationnels sont apportés.

2) Les avantages de la détection basée sur le comportement sont les suivants

a) Il n'est pas nécessaire de connaître les nouvelles techniques d'intrusion spécifiques.

b) Il est moins spécifique à des systèmes d'exploitation particuliers.

g. Les réponses à la détection d'une intrusion comprennent normalement un composant automatique. La surveillance et l'intervention continues des individus peuvent ne pas être réalisables ou ne pas être suffisamment rapides.

1) Un SDI à action automatique assure une sécurité continue. Il répond sans la présence de l'homme. Les réponses peuvent inclure

a) Déconnexion de l'ensemble du réseau à partir d'un accès extérieur

b) Verrouillage de l'accès à tout ou partie du système

c) Ralentissement de l'activité du système pour réduire les blessures

d) Validation de l'utilisateur externe

e) Envoi de messages par console, courriel, téléavertisseur ou téléphone au personnel approprié

2) Les ressources du système d'alarme sont des fichiers factices ou des comptes, par exemple, un compte administrateur par défaut avec un mot de passe par défaut. Ce sont des pièges pour un intrus.

a) L'accès à une ressource fictive entraîne une action ou un avis automatique aux employés concernés.

b) L'avantage de cette méthode est qu'elle est simple et peu coûteuse.

c) L'inconvénient est que les personnes autorisées peuvent, par inadvertance, déclencher une alarme.

6. Intégrité et fiabilité de l'information

a. Les auditeurs internes évaluent souvent les pratiques de l'organisation en matière d'intégrité et de fiabilité de l'information.

1) Les auditeurs internes s’assurent que la direction générale et le Conseil sont conscients de la responsabilité du management en matière de fiabilité et d’intégrité de l’information. Cette responsabilité porte sur toutes les informations essentielles pour l’organisation, quel que soit leur mode de conservation. La fiabilité et l’intégrité de l’information incluent l’exactitude, l’exhaustivité et la sécurité.

2) Le responsable de l'audit interne s’assure que l’audit interne dispose ou a accès à des ressources appropriées pour évaluer la fiabilité et l’intégrité de l’information et les risques correspondants. Ces derniers incluent tant les risques internes que les risques externes et, ceux afférents aux relations établies par l’organisation avec d’autres entités externes.

3) Le responsable d’audit interne s’assure que la direction générale, le Conseil et l’audit interne seront rapidement informés de toute atteinte à la fiabilité et à l’intégrité de l’information et de toute situation susceptible de constituer une menace pour l’organisation.

4) Les auditeurs internes évaluent, le cas échéant, l’efficacité des mesures prises, en vue de prévenir, détecter et atténuer les attaques survenues par le passé, ainsi que tout incident ou tentative d'attaque susceptible de se produire à l'avenir. Les auditeurs internes s’assurent que le Conseil a bien été informé des menaces ou incidents survenus, des faiblesses exploitées et des mesures correctives.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

5) Les auditeurs internes évaluent périodiquement le dispositif de fiabilité et d'intégrité de l'information de l'organisation et recommandent, le cas échéant, des améliorations ou la mise en place de nouveaux contrôles et de nouvelles mesures de protection. Ces évaluations peuvent faire l'objet de missions distinctes et isolées ou être intégrées dans d'autres missions réalisées dans le cadre du plan d'audit annuel. Le processus de communication approprié à la direction générale et au Conseil dépendra de la nature de la mission.

7. Vie privée

a. Il incombe à la direction de s'assurer que le cadre de protection de la vie privée d'une organisation est en place. Le rôle principal des auditeurs internes est de s'assurer que les lois sur la protection des renseignements personnels et les autres règlements pertinents sont bien communiqués aux parties responsables.

1) Les risques associés à la protection des renseignements personnels comprennent l'intimité des personnes (sur le plan physique et psychologique), le respect de l'espace privé (absence de surveillance), ainsi que le caractère confidentiel de la communication (absence de contrôle) et des informations (collecte, exploitation et diffusion par autrui d'informations à caractère personnel).

a) Les renseignements personnels sont des renseignements associés à une personne en particulier.

2) Un contrôle efficace de la protection des renseignements personnels est une composante essentielle des processus de gouvernance, de gestion des risques et de contrôle d'une organisation. Le conseil d'administration est ultimement responsable de l'identification des principaux risques pour l'organisation et de la mise en œuvre de processus de contrôle appropriés pour atténuer ces risques. Cela comprend l'établissement du cadre de protection de la vie privée nécessaire pour l'organisation et la surveillance de sa mise en œuvre.

3) En procédant à une telle évaluation de la gestion du cadre de protection de la vie privée de l'organisation, l'auditeur interne

a) Tient compte des lois, des règlements et des politiques en matière de protection de la vie privée dans les territoires où l'organisation exerce ses activités et où l'information voyage et est stockée ;

b) Assure la liaison avec les conseillers juridiques internes afin de déterminer la nature exacte des lois, règlements et autres normes et pratiques applicables à l'organisation et au(x) pays dans lesquels elle opère ;

c) Assure la liaison avec les spécialistes des technologies de l'information afin de déterminer si des mesures de contrôle de la sécurité de l'information et de la protection des données sont en place et si elles sont régulièrement examinées et évaluées pour déterminer si elles sont appropriées ; et

d) Tient compte du niveau ou de la maturité des pratiques de l'organisation en matière de protection de la vie privée. Selon le niveau, l'auditeur interne peut avoir des rôles différents.

4) Les violations des lois et règlements sur la protection de la vie privée peuvent entraîner des amendes, des poursuites civiles et nuire à la réputation de l'organisation.

b. Le Règlement général sur la protection des données (RGPD) de l'Union européenne (UE), promulgué le 25 mai 2018, stipule que toute organisation ayant une présence sur Internet dans l'UE est tenue de se conformer à ce qui suit ou est passible d'amendes pouvant atteindre 4 % sur la base des ventes mondiales de l'organisation ou 20 millions €, selon le montant le plus élevé :

1) Obtenir l'approbation des citoyens de l'UE avant de traiter ou de transférer des données à caractère personnel

2) Fournir des notifications d'atteinte à la protection des données

3) Pour certaines organisations, exiger la nomination d'un délégué à la protection des données pour surveiller la conformité au Règlement général sur la protection des données (RGPD).

8. Les nouvelles pratiques technologiques et leur impact sur la sécurité

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

a. Les organisations (y compris les auditeurs internes) doivent évaluer l'incidence sur la sécurité de l'information à mesure que la technologie s'améliore et est remplacée par des technologies plus avancées, comme celles qui suivent :

1) **Les machines intelligentes** sont des technologies d'automatisation qui permettent d'exécuter des processus ou des procédures sans assistance humaine.

a) En général, les caractéristiques de la technologie des machines intelligentes comprennent, sans s'y limiter, (1) l'apprentissage et le fonctionnement autonomes, (2) l'adaptation de leur comportement en fonction de leur expérience (apprentissage) et (3) la production de résultats imprévus. Les machines intelligentes comprennent :

i) Les voitures autonomes

ii) Robots

iii) Comptoirs de caisse en service libre dans un supermarché

2) **Bring your own device (BYOD)** est un concept où les personnes associées à l'organisation (c.-à-d. les propriétaires d'entreprise, les employés, les clients, les fournisseurs, etc.) utilisent leurs propres appareils informatiques pour accéder aux applications informatiques de l'organisation afin de faire des affaires.

3) L'**Internet des objets (IoT)** est la connexion d'appareils autres que les ordinateurs et les smartphones à Internet. Les voitures, les moniteurs médicaux, les alarmes résidentielles et commerciales et les puces de localisation implantées chez les animaux sont des exemples de dispositifs qui peuvent être connectés via l'IdO.

b. Les risques associés à l'utilisation d'une technologie intelligente pour accéder aux systèmes d'information d'une organisation sont les suivants :

1) Les risques de **conformité** impliquent que les utilisateurs de la technologie intelligente contournent les contrôles ou omettent d'installer des mises à jour qui exposent l'organisation à des vulnérabilités et entraînent des temps d'arrêt du système.

2) Les risques d'atteinte à la **vie privée** vont de la protection des renseignements personnels auxquels on a accès ou qui sont stockés sur un dispositif intelligent aux préoccupations des utilisateurs selon lesquelles l'organisation surveille l'utilisateur.

3) Les risques de sécurité comprennent la sécurité physique et la sécurité des données.

a) Les risques de **sécurité physique** sont associés aux dispositifs intelligents en raison de leur portabilité. L'information peut devenir vulnérable à une mauvaise utilisation en cas de vol ou de perte du dispositif intelligent ou si le dispositif n'est pas nettoyé de toutes les données associées à l'organisation lorsque l'utilisateur quitte celle-ci.

b) Les risques liés à la **sécurité des données** impliquent un accès non autorisé à l'information par des méthodes qui comprennent, sans toutefois s'y limiter, le contournement des protocoles de sécurité des systèmes d'exploitation des dispositifs intelligents, des connexions réseau non sécurisées et des applications non autorisées.

c. Les contrôles qui réduisent ou éliminent généralement les risques associés à l'utilisation d'une technologie intelligente pour accéder aux systèmes d'information d'une organisation sont les suivants :

1) **L'authentification** restreint l'utilisation du dispositif intelligent aux seuls utilisateurs autorisés.

2) **L'effacement à distance** est le processus de suppression de données et d'applications sans accès physique à l'appareil intelligent.

3) **Cryptage des** données en transit et stockées sur l'appareil intelligent.

4) **Les logiciels anti malveillants** protègent contre les logiciels malveillants.

5) Une **politique BYOD** englobe des contrôles tels que :

a) Dispositifs approuvés

b) Signalisation de la perte ou le vol d'appareils

c) Utilisation de réseaux sécurisés uniquement

d) Utilisation des applications autorisées seulement

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

e) Ne pas contourner les protocoles de sécurité des systèmes d'exploitation des dispositifs intelligents

8.4 : PLANIFICATION D'URGENCE ET REPRISE APRÈS SINISTRE

1. Vue d'ensemble

a. L'objectif de sécurité de l'information que constitue la disponibilité des données relève principalement de la responsabilité de la fonction informatique.

b. La planification d'urgence est le nom communément donné à cette activité.

1) **La reprise après sinistre** est le processus de reprise des opérations normales de traitement de l'information après la survenance d'une interruption majeure.

2) **La continuité des activités** est la poursuite des activités par d'autres moyens pendant la période au cours de laquelle le traitement informatique n'est pas disponible ou est inférieur à la normale.

c. Il faut prévoir deux grands types d'imprévus : ceux dans lesquels le centre de données est physiquement disponible et ceux dans lesquels il ne l'est pas.

1) Parmi les exemples du premier type d'urgence, mentionnons a) les pannes de courant, b) les intrusions aléatoires comme les virus et c) les intrusions délibérées comme les actes de piratage informatique. Les installations matérielles de l'organisation sont en bon état, mais des mesures immédiates sont nécessaires pour poursuivre le traitement normal.

2) Le deuxième type d'urgence est beaucoup plus grave. Elle est causée par des catastrophes telles que des inondations, des incendies, des ouragans ou des tremblements de terre. Une occurrence de ce type nécessite une autre installation de transformation.

2. Sauvegarde et rotation

a. La sauvegarde périodique et la rotation hors site des fichiers informatiques est la partie la plus fondamentale de tout plan de reprise après sinistre ou de continuité des activités.

1) Les données d'une organisation ont plus de valeur que son matériel. Le matériel peut être remplacé pour un certain prix, mais les données de chaque organisation sont uniques et indispensables aux opérations. Si elles sont détruites, elles ne peuvent être remplacées. Pour cette raison, la sauvegarde et la rotation périodiques sont essentielles.

b. Une routine de sauvegarde typique duplique tous les fichiers de données et programmes d'application une fois par mois. Les modifications incrémentales sont ensuite sauvegardées et apportées à un emplacement hors site une fois par semaine. (Les fichiers d'application et les données doivent être sauvegardés car les deux changent.)

1) En cas d'interruption du traitement normal, les systèmes de l'organisation peuvent être restaurés de manière à ce que, au maximum, 7 jours d'informations commerciales soient perdus. Ce n'est pas l'idéal, mais c'est préférable à une perte totale de dossiers qui pourrait ruiner l'organisation.

c. L'emplacement hors site doit être à température et humidité contrôlées et protégé contre les intrusions physiques. Tout aussi important, il doit être suffisamment éloigné du site des opérations principales pour ne pas être affecté par la même catastrophe naturelle. Une sauvegarde adéquate est inutile si les fichiers ne sont pas accessibles ou ont été détruits.

3. Étapes de l'évaluation des risques

a. Identifier et prioriser les applications critiques de l'organisation.

1) Tous les systèmes d'une organisation n'ont pas la même importance. L'entreprise doit décider des applications vitales dont elle ne peut tout simplement pas se passer et dans quel ordre elles doivent être remises en service.

b. Déterminez les durées minimales de reprise et la configuration matérielle minimale requise.

1) Combien de temps faudra-t-il pour réinstaller chaque application critique, et quelle plate-forme est requise ? Si l'interruption a été causée par une attaque, comme un virus ou un pirate informatique, combien de temps faudra-t-il pour isoler le problème et l'éliminer du système ?

c. Élaborer un plan de reprise.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

4. Plan de reprise après sinistre (PRS)

a. La reprise après sinistre est le processus de reprise de l'accès aux données (p. ex., matériel, logiciels et dossiers), aux communications, aux secteurs de travail et aux autres processus opérationnels.

b. Ainsi, un PRS établi et mis à l'essai doit être élaboré dans le cadre du plan de continuité des activités. Il devrait décrire les stratégies de reprise des TI, y compris des détails sur les procédures, les fournisseurs et les systèmes.

1) Les procédures détaillées doivent être mises à jour lorsque les systèmes et les activités changent. Voici des exemples d'éléments traités par le PRS :

a) Centre de données

b) Applications et données nécessaires

c) Serveurs et autres matériels

d) Communications

e) Connexions réseau

f) Infrastructure de TI (p. ex. services de connexion et distribution de logiciels)

g) Services d'accès à distance

h) Systèmes de contrôle de processus

i) Salles des dossiers

j) Systèmes de gestion de documents

c. Les considérations suivantes vous aideront à choisir des stratégies de PRS :

1) Le PRS devrait être fondé sur l'analyse des répercussions sur les activités (dont il est question en détail à la page 20).

2) La capacité de reprise des fournisseurs de services essentiels doit être évaluée.

3) La restauration des composants informatiques doit souvent être combinée pour restaurer un système.

4) Les fournisseurs de services (internes et externes) doivent fournir des renseignements sur le reprise, comme leurs a) responsabilités, b) limites, c) activités de reprise, d) délais et objectifs de reprise, et e) coûts.

5) Les stratégies pour les composantes peuvent être élaborées de façon indépendante. L'objectif est de trouver la solution la meilleure et la plus rentable pour (a) permettre l'accès des utilisateurs et (b) permettre aux composants de travailler ensemble, quel que soit l'endroit où les systèmes sont récupérés.

6) Les normes de sécurité et de conformité doivent être prises en compte.

5. Éventualités avec le centre de données disponible

a. L'achat de groupes électrogènes de secours protège contre les pannes de courant. Ceux-ci peuvent être programmés pour commencer à fonctionner automatiquement dès qu'une chute de courant électrique est détectée. Cette pratique est très répandue dans des milieux comme les hôpitaux, où la disponibilité 24 heures sur 24 est cruciale.

b. Les attaques telles que les virus et le déni de service exigent une réponse complètement différente. Le système doit être abaissé avec grâce pour arrêter la propagation de l'infection. Le personnel informatique doit être bien formé à la nature des dernières menaces virales pour savoir comment isoler les dégâts et remettre le système en service.

6. Éventualités liées à l'indisponibilité d'un centre de données

a. L'éventualité la plus extrême est une catastrophe qui rend inutilisable l'installation principale de l'organisation. Pour se préparer à ces cas, les organisations passent des marchés avec d'autres installations de traitement.

b. Une **autre installation de traitement** est un emplacement physique entretenu par un entrepreneur externe dans le but de fournir des installations de traitement aux clients en cas de sinistre.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

1) Le centre de reprise, tout comme le lieu de stockage hors site des fichiers de sauvegarde, doit être suffisamment éloigné de l'installation principale pour qu'il ne soit pas affecté par la même catastrophe naturelle. Habituellement, les organisations passent des contrats pour des installations de secours dans une autre ville.

2) Lorsque le traitement n'est plus possible sur le site principal, les fichiers de sauvegarde sont récupérés à partir de l'emplacement de stockage sécurisé et transférés au centre de reprise.

c. Les centres de reprise prennent plusieurs formes de base. Les organisations déterminent quelle installation est la meilleure en calculant le compromis entre le coût du contrat et le coût du temps d'arrêt.

1) Un **centre de secours immédiat** est une installation de traitement pleinement opérationnelle qui est immédiatement disponible. L'organisation passe généralement un contrat avec un fournisseur de services.

a) Contre rémunération, le fournisseur de services accepte d'avoir une plateforme matérielle et des lignes de communication essentiellement identiques à celles de l'organisation, prêtes à être utilisées 24 heures par jour, 365 jours par an.

b) Cette solution est la moins risquée et la plus chère.

c) Tout contrat pour un centre de secours immédiat doit inclure une disposition sur les tests annuels.

i) Le fournisseur de services convient d'un délai dans lequel l'organisation peut déclarer un faux sinistre, charger ses fichiers de sauvegarde sur l'équipement sur le centre de secours immédiat et déterminer combien de temps il faut pour reprendre le traitement normal.

2) Un **centre de secours graduel** est une installation coquillière dotée d'une alimentation électrique, de contrôles environnementaux et de lignes de communication suffisants pour permettre à l'organisation d'installer son propre équipement nouvellement acquis.

a) De façon continue, cette solution est beaucoup moins coûteuse.

b) Cependant, le temps nécessaire pour se procurer de l'équipement de remplacement peut prendre des semaines ou des mois. De plus, l'approvisionnement d'urgence auprès de fournisseurs d'équipement peut être très coûteux.

3) Un **centre de secours intermédiaire** est un compromis entre un centre de secours graduel et un centre de secours immédiat, combinant les caractéristiques des deux.

a) Les ressources sont disponibles sur le site, mais il peut être nécessaire de les configurer pour prendre en charge le système de production.

b) Certaines données peuvent avoir besoin d'être restaurées.

c) Le temps de reprise typique varie de 2 jours à 2 semaines.

4) Un **accord de réciprocité** peut être conclu avec une ou plusieurs organisations pour partager des ressources si une partie est victime d'une défaillance. Les auditeurs doivent s'assurer que toutes les parties restent synchronisées sur le plan technique.

5) Une **multipropriété en temps partagé** est une stratégie de continuité dans laquelle une organisation loue une installation de sauvegarde avec une organisation partenaire. Cela permet à l'organisation de disposer d'une option de sauvegarde tout en réduisant les coûts globaux.

7. Tolérance de pannes

a. Un ordinateur à tolérance de pannes possède des puces et un stockage sur disque supplémentaires ainsi qu'une alimentation de secours. Cette technologie est utilisée pour les applications critiques qui ne peuvent pas se permettre de subir des temps d'arrêt.

1) La technologie qui permet la tolérance aux pannes est le réseau redondant de disques bon marché (ou indépendants), ou RAID. Il s'agit d'un groupe de disques durs multiples avec un logiciel spécial qui permet la transmission des données sur plusieurs chemins. Si un lecteur tombe en panne, les autres disques peuvent compenser la perte.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

b. Les composants à tolérance de pannes ont des redondances matérielles ou logicielles pour permettre la poursuite des opérations si un système tombe en panne.

c. L'Informatique à haute disponibilité est utilisé pour les applications moins critiques car il permet un temps de reprise court plutôt que l'élimination du temps de reprise.

8. Aperçu de la gestion de la continuité des activités (GCA)

a. L'objectif de GCA est de restaurer les processus critiques et de minimiser les effets financiers et autres d'une catastrophe ou d'une interruption des activités.

b. La GCA est le troisième volet d'un programme de gestion des urgences. Sa durée est mesurée en heures et en jours, voire en semaines. Les autres composantes sont les suivantes

1) L'intervention d'urgence, dont le but est de sauver des vies, la sécurité et les efforts initiaux visant à limiter les effets d'une catastrophe aux dégâts matériels. Sa durée est mesurée en heures sinon en minutes.

2) La gestion de crise, qui est axée sur la gestion des activités de communication et des cadres supérieurs. Sa durée est mesurée en jours voire en heures.

9. Éléments de la GCA

a. **Soutien à la gestion**

1) La direction doit affecter des ressources adéquates à la préparation, au maintien et à la mise en pratique d'un plan de continuité des activités.

b. **Évaluation et atténuation des risques**

1) L'entité doit (a) définir des événements de risque crédibles (menaces), (b) évaluer leurs effets et (c) élaborer des stratégies d'atténuation des risques.

c. **Analyse de l'impact sur les activités**

1) Cette analyse identifie les processus d'affaires nécessaires pour fonctionner en cas de sinistre et détermine à quel moment ils doivent être récupérés.

2) L'organisation (a) identifie les processus critiques, (b) définit un objectif de temps de reprise (RTO) et un objectif de point de reprise (RPO) pour les processus et les ressources, et (c) identifie les autres parties (fournisseurs et autres divisions de l'organisation) et les ressources matérielles (équipement et dossiers critiques) nécessaires au reprise.

a) Un objectif de temps de reprise est la durée et le niveau de service dans lequel un processus doit être restauré. Un objectif de point de reprise est la quantité de données que l'organisation peut se permettre de perdre.

b) Le coût d'une solution de reprise augmente habituellement à mesure que l'un ou l'autre des objectifs diminue.

d. **Stratégie de reprise et de continuité des activités**

1) Un élément crucial de la reprise des activités est l'existence d'un plan de reprise après sinistre complet et à jour, qui aborde les étapes réelles, les personnes et les ressources nécessaires pour reprendre un processus opérationnel essentiel. (Les plans de reprise après sinistre ont été examinés plus en détail précédemment.)

2) L'organisation envisage :

a) Un personnel de remplacement (par exemple, le personnel restant sur le site, le personnel d'un autre site ou le personnel d'une autre organisation),

b) De recourir à des sources alternatives (par exemple, utilisation de produits et services non standard, utilisation de fournisseurs divers, sous-traitance à des organisations fournissant des services standard ou accords de reprise après sinistre avec des concurrents),

i) Lorsqu'on examine les ententes réciproques de reprise après sinistre, la principale préoccupation est de savoir si le matériel et les logiciels des organisations participantes sont compatibles.

c) Des espaces de travail alternatifs (par exemple, une autre installation, un accès distant avec une sécurité appropriée ou un site de récupération commercial), et

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.

d) Le retour à un fonctionnement normal (par exemple, la saisie de données traitées manuellement, la résolution des exceptions réglementaires et financières, la restitution du matériel emprunté et le réapprovisionnement en produits et fournitures).

e. **Éducation, sensibilisation et entretien**

1) L'éducation et la sensibilisation (y compris les exercices de formation) sont essentielles à la GCA et à l'exécution du plan de continuité des opérations.

2) Les capacités et la documentation de la GCA doivent être maintenues pour s'assurer qu'elles demeurent efficaces et harmonisées avec les professionnels du monde des affaires.

f. **Continuité des activités**

1) Selon l'IIA, des exercices (ou tests) à grande échelle des programmes de GCA et des plans de la CA. devraient être effectués au moins une fois par année.

2) Les exercices suivants sont différents types d'exercices :

a) Une **vérification documentaire** est un examen du plan écrit pour s'assurer de l'exactitude de la documentation. C'est le type d'exercice ou de test le moins invasif.

b) La méthode d'**orientation** ou de visite du plan permet de s'assurer que tous les membres de l'équipe comprennent leurs nouveaux rôles ainsi que le contenu et le format de base du plan. Cette méthode permet aux employés qui doivent mettre en œuvre le plan de parcourir le document de façon informelle. Normalement, ce type d'événement de faible intensité ne constitue pas un test.

c) Un **exercice sur table** simule une situation d'urgence dans un environnement informel et sans stress. Le but est d'aider les membres de l'équipe à comprendre l'importance de leurs rôles et responsabilités.

d) **Les tests de communication** impliquent normalement un contact réel avec les partenaires commerciaux et les employés. Les objectifs comprennent (1) la validation des coordonnées des principaux intervenants, (2) la formation des participants sur la façon d'utiliser la notification de masse et d'assumer d'autres rôles dans l'intervention, (3) la configuration adéquate des outils de notification de masse et (4) l'identification des lacunes en matière de communication lorsque la communication en temps opportun pourrait être compromise pendant une catastrophe.

e) **Le passage en revue de l'environnement informatique** consiste à effectuer une simulation de sinistre annoncée ou non annoncée et à exécuter des procédures documentées de reprise des activités du système.

f) **Tests alternatif du site**. Les participants testent la capacité de transférer le personnel à un autre site, de restaurer les processus et de récupérer les données, comme prévu. Ce type de test :

i Démontre la capacité réelle de l'autre site.
ii Indique si la confidentialité et la sécurité peuvent être maintenues à l'autre site.
iii Forme le personnel aux processus et à l'équipement sur le site.
iv Confirme la suffisance et l'efficacité des biens des TI à un autre site.

g) **Les tests de bout en bout** déterminent si une application fonctionne comme prévu du début à la fin. Le test valide la connectivité au site de production de l'organisation.

Copyright © 2018 Gleim Publications, Inc. Tous droits réservés. Reproduction interdite. Récompense pour les informations dénonçant les contrevenants. Contactez copyright@gleim.com.